BSV Unified Identity: Technical White Paper

Private, Verifiable, Unlinkable KYC, from BRC-100 Wallets to eIDAS

---

v0.2 Siggi (BSV Association); additional editors TBD

Contents

1. Introduction 1
2. The problem and the regulatory window 2
3. Architecture at a glance 2
4. The cryptographic core 3
5. Identifier and keys 4
6. Identity model 5
7. KYC tiers and assurance 5
8. Credentials and presentation 6
9. The zero-knowledge toolbox 7
10. eIDAS interoperability 8
11. Security and privacy 9
12. How it compares 10
13. Roadmap and status 10

1. Introduction

Digital identity has a structural defect: it makes you choose between being verifiable and being private, and it almost never lets you be unlinkable. Prove who you are to a service and you typically hand over a document that is then stored, reused, and correlated across services into a profile. Stay private and you are reduced to self-asserted claims a counterparty cannot check. KYC sharpens the defect into a paradox: the more rigorously identity is verified, the more widely it leaks.

This work proposes a unified identity layer for the BSV blockchain whose defining property is **KYC that is private, verifiable, and unlinkable at once**. A holder proves they are a real, current, uniquely-identified person who satisfies stated predicates (over 18, EU-resident, assured to some level) without revealing who they are, and presents a *different* identifier to every relying party, so activity cannot be correlated across services even when those services collude. One scope boundary is stated up front: the unlinkable predicate pattern legally serves age verification, Sybil resistance, and access gating. Where anti-money-laundering law requires customer due diligence, the obliged entity must identify the customer and retain identity data, and there the layer's offer is verifiable, minimized disclosure, not unlinkability (Spec §10.9). Under the optional delegated-custody profile the obliged entity holds no plaintext identity data at all: an accredited custodian retains the record under split-key custody, while the business holds a verifiable proof of due diligence, a per-relationship cryptographic anchor, and a sealed retrieval right exercisable on lawful triggers (Spec §10.10).

Two design commitments run through the paper. The first is **reuse over reinvention**: the layer binds primitives that already exist, namely a registered DID method, W3C Verifiable Credentials, the OpenID and ISO presentation protocols the EU mandates, and BSV's own key and certificate schemes, rather than minting new ones. The second is **honesty about maturity**: the free entry tier is bootstrap-grade, the heaviest zero-knowledge proofs are real engineering, network privacy is a separate problem from cryptographic unlinkability, and government-grade recognition is a long-horizon, politically-gated destination. Each of these is stated plainly where it arises.

2. The problem and the regulatory window

Centralized identity fails in three predictable ways. Aggregated identity stores are breach honeypots whose compromise is catastrophic and irreversible. Paper and PDF credentials are forgeable and slow to verify. And because the same identifiers are presented everywhere, ordinary use produces pervasive cross-service correlation as a side effect. KYC compounds all three: establishing who a counterparty is normally requires surrendering a full document to each counterparty, where it is stored and exposed.

A UTXO blockchain is well suited to breaking this. Transaction chains give an immutable, block-ordered, double-spend-protected record, which is what credential issuance, key rotation, and revocation need, verifiable under simplified payment verification (SPV) against the header chain, paired with an authenticated current-state proof, without trusting a central index. (SPV proves inclusion, not the absence of a later spend, and block time is approximate ordering, not a qualified timestamp; Spec §7.6.) BSV adds low-fee, high-throughput anchoring, and `did:bsv` is already registered and resolvable, so the identifier layer need not be invented.

The timing is set by regulation. eIDAS 2.0 (Regulation (EU) 2024/1183) requires every member state to make at least one EU Digital Identity Wallet available: the first implementing regulations were published in December 2024, putting national wallet availability at late December 2026 on the regulation's 24-month clock, with mandatory acceptance by specified relying parties (regulated sectors requiring strong authentication, and very large online platforms) following about a year later. Readiness is lagging, with fewer than a third of member states meeting the readiness benchmark and several national wallets slipping into 2027, which widens rather than narrows the window for a standards-aligned entrant. The Architecture and Reference Framework (ARF) is now on a structured iterative release cycle (v2.9.0 as of May 2026). The specific gap the work targets is **unlinkability**: the EU's mainstream selective-disclosure formats (SD-JWT VC, mdoc) are linkable across colluding verifiers, and although the ARF has now taken up zero-knowledge proof as a first-class topic (high-level requirements in its Annex 2, referencing ETSI TR 119 476), it defers deployment to *after* the December 2026 launch, over credentials already issued in those linkable formats. So the live differentiator is unlinkable-by-default, from day one, with offline presentation, and not a claim that the EU ignores the property.

3. Architecture at a glance

BSV already carries most of the machinery an identity system needs, but it grew as **two largely separate stacks** that were never designed to interlock. The first is a wallet/attestation stack: per-protocol, per-counterparty key derivation (BRC-42/43), a vendor-neutral wallet-to-application interface (BRC-100), peer-to-peer mutual authentication with selective disclosure (BRC-103), and privacy-centric identity certificates (BRC-52/53). The second is a Verifiable-Credential / DID stack instantiated on BSV by TNG Identity: the registered `did:bsv` method, W3C Verifiable Credentials and Presentations, and OpenID/SIOP reach into the Web2 world. The first stack has excellent keys and authenticated sessions but no resolvable, standards-registered identifier and no native bridge to the VC/eIDAS world; the second has the identifier and the credentials but does not exploit type-42 derivation or keyring selective disclosure and inherits the linkability of mainstream credential formats. Neither, alone, delivers private-verifiable-unlinkable KYC.

The proposal is a single **binding layer**, a new BRC, that sits over both stacks and composes them, with a zero-knowledge toolbox that turns selective disclosure into unlinkable, predicate-bearing, uniqueness-aware presentation. The same identity serves a BSV-native application (over BRC-103) and an eIDAS relying party (over OpenID4VP/SIOP) without re-issuance.

Figure 1 · Layered architecture

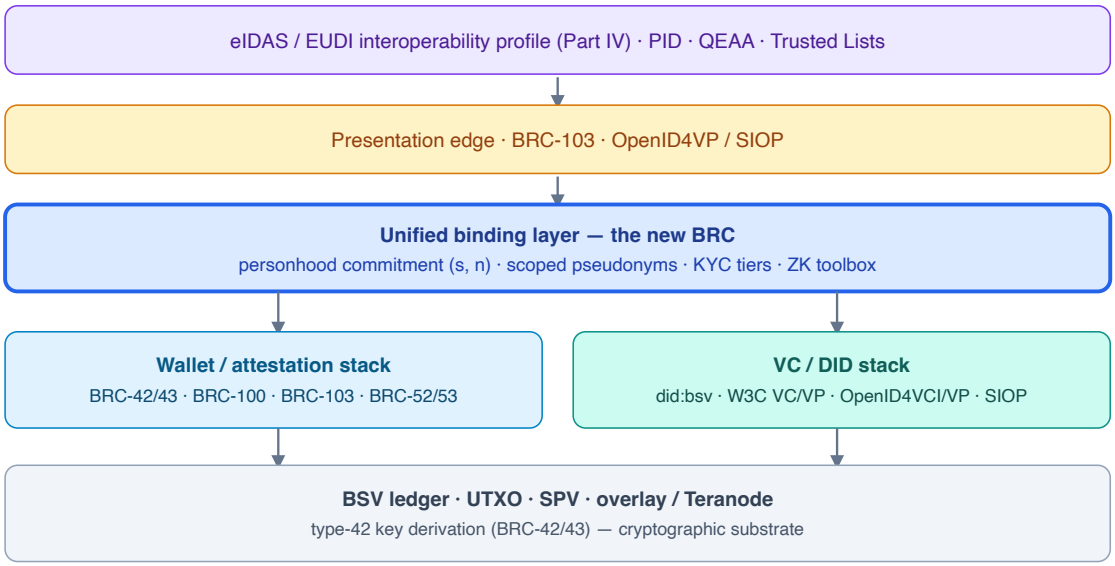


Figure 1. The ledger and type-42 derivation form the foundation; the two native stacks are parallel pillars; the binding layer spans both and is where the personhood commitment, pseudonyms, tiers, and zero-knowledge proofs live; the presentation edge speaks both protocol worlds. (Spec §6.)

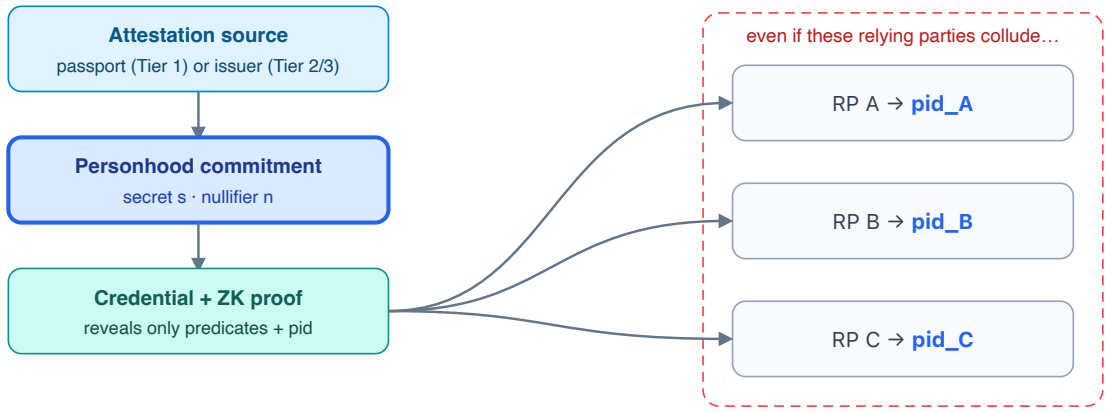
4. The cryptographic core

The heart of the design is the separation of three values. Collapsing them is the classic mistake that quietly destroys either privacy or uniqueness; keeping them distinct is what lets the system be private, verifiable, and unlinkable simultaneously.

- The **presentation secret `s`** is a high-entropy value derived from the holder's root secret under a dedicated domain separator, held only in the wallet and never disclosed. It is the source of the holder's per-service pseudonyms and of holder binding. Because it is derived from the root secret, the same backup that protects signing keys restores it; because it is independent of any individual signing key, a holder's relationships survive key rotation and recovery unchanged. (Spec §8.4.)
- The **personhood nullifier `n`**, the "uniKey", is a deterministic, one-way function of the holder's passport identity: the document number, the machine-readable-zone fields, and the hash of the chip's Document Security Object (SOD). The SOD hash makes `n` computable only by someone who has actually read the chip, not from a photocopy of the photo page, without touching biometric data (the facial-image hash of earlier drafts is deliberately excluded; deriving a uniqueness identifier from a facial image is special-category processing under GDPR Art. 9 and adds no uniqueness). `n` anchors document-level uniqueness, meaning at most one active enrolment per supported passport document, which is the honest strength of the claim (§7), and the same passport always yields the same `n`, even from a fresh wallet. **`n` is not a secret**, since anyone who has read the passport chip can recompute it, so `n` is used exactly once, at enrolment, to key the uniqueness registry, and **no `n`-derived value ever appears in a presentation**. Anything derived from `n` that a relying party stores would be recomputable by whoever has handled the passport and would become a join key against the holder's real identity; that is the failure mode the design exists to prevent.
- The **scoped pseudonym `pid = PRF(s, scope)`** is what a relying party actually sees and stores: stable for that relying party (so a relying party can enforce one account per returning holder locally, which at Tier 1 is one per enrolled document, not provably one per person), uncorrelated with the pseudonym the same person presents anywhere else, and one-way (a `pid` reveals nothing about `s`, the root identity, or any other `pid`).

A presentation proves, in zero knowledge, that the holder knows a secret `s` and a credential `C` such that `C` commits to `s` (and, where uniqueness applies, to `n`); `C` is validly attested at or above the required tier; `C` is current and, where uniqueness applies, an active member of the anchored enrolment registry, proven without revealing which member; the requested predicates hold; and `pid = PRF(s, scope)`, revealing only `pid`, the truth of the predicates, and the satisfied tier. `C` itself stays hidden behind the membership proof: a commitment shown verbatim at every presentation would itself link the holder across services. Registry-wide per-document uniqueness is enforced where it belongs, at enrolment, as one active registration per `n` (that is, per document) in the registry, so nothing person-derived needs to be revealed at presentation time.

Figure 4 · Unlinkable KYC — one person, a different identifier per service



Every presentation is verifiable; the pseudonyms stay unlinkable across services — correlation remains infeasible even under collusion.

Figure 4. The core pattern (Spec §10). One commitment, a distinct stable pseudonym per relying party, all verifiable, none correlatable.

5. Identifier and keys

The root identity is a `did:bsv` DID, a UTXO-friendly method listed in the W3C DID extensions registry (a discovery registry, not a W3C endorsement; its specification and reference resolver are currently single-vendor, which the Spec addresses through multi-vendor resolution requirements), in which creation, key rotation, controller change, and revocation are recorded as transaction-chain operations, each spending the prior state to give a unique, ordered, timestamped history. The method supports a 1-of-2 arrangement under which either the controller or the subject can unilaterally **deactivate**, while a DID Document update, including key rotation, requires **both** signatures (2-of-2); where a controller will not co-sign, the subject's independent recourse is to deactivate and create a successor DID. In the self-sovereign default the holder is both. The current DID Document is reconstructed deterministically from the chain and verified under SPV. The reference resolver can load history from a public indexer, but the profile makes BSV-native resolution (overlay services / Teranode) the normative path so resolution does not depend on a single third party. (Spec §7, Appendix B.)

One rule is load-bearing for unlinkability: **the root DID is never presented to relying parties.** It is the control and recovery anchor; relying parties receive only per-RP pseudonyms.

All keys are secp256k1 and all signatures are DER-encoded ECDSA, including the BRC-103 handshake, which delegates signing to the BRC-100 wallet mechanisms (an earlier draft said Schnorr; the published BRCs say otherwise). Keys derive under type-42 (BRC-42/43) from a single root secret: using the relying party as the derivation counterparty yields a distinct signing key per relationship, so signing keys, like pseudonyms, do not correlate across relying parties. Custody is **non-custodial by default**, and the design is candid that this is a place real deployments drift: convenience pressure pushes toward custodial

wallets, and a custodial wallet can correlate a holder across relying parties internally even when the on-the-wire identifiers stay pairwise, so a custodial deployment must disclose that, and the non-custodial option must remain available at every tier. Recovery uses mechanisms that do not surrender custody (social recovery, threshold/MPC shares, hardware backup), expressed as controller-authorized key rotations. Optionally, a FIDO2/WebAuthn authenticator can gate access to the secure element holding the keys, raising the authenticator-assurance level without changing the identity tier. (Spec §8.)

6. Identity model

The model has three levels. The **root personhood identity** is one `did:bsv` per person *as the intended wallet model*, though nothing in the protocol prevents a person from creating several, particularly at Tier 0 (§7). It carries the personhood commitment and is never presented directly. **Per-RP pairwise identifiers** are the scoped pseudonym plus a per-RP presentation key, which is what relying parties see and store. **Personas** are optional context identities (professional versus personal), each able to hold its own credentials, optionally provable as sharing the same personhood commitment when uniqueness is required.

Two properties hold together. *Unlinkability:* distinct relying parties receive uncorrelated identifiers, and correlation stays infeasible even if they pool their data. *Uniqueness:* because all of a holder's pseudonyms derive from one secret `s` and uniqueness rests on one nullifier `n`, the system can prove **one active enrolment per passport document** while keeping the pseudonyms unlinkable; a per-person claim is available only at the accountable tiers (§7). The scope of any uniqueness guarantee, per-RP or registry-wide (per document), is a deliberate choice, discussed in §7. (Spec §9.)

7. KYC tiers and assurance

Identity is anchored to a single persistent `did:bsv` and, from Tier 1 upward, one persistent personhood commitment, over which assurance accrues as additive attestations. A holder may begin at any tier and upgrade; pseudonyms and relationships stay stable across upgrades. A central principle separates two ideas routinely conflated: **cryptographic authenticity is not identity assurance level.** A self-read passport can yield data that is provably genuine and provably from an un-cloned chip, yet still sit at the lowest assurance, because no accountable party has verified that the person presenting it is its rightful holder.

Figure 2 · Tier progression — assurance accrues over one identity

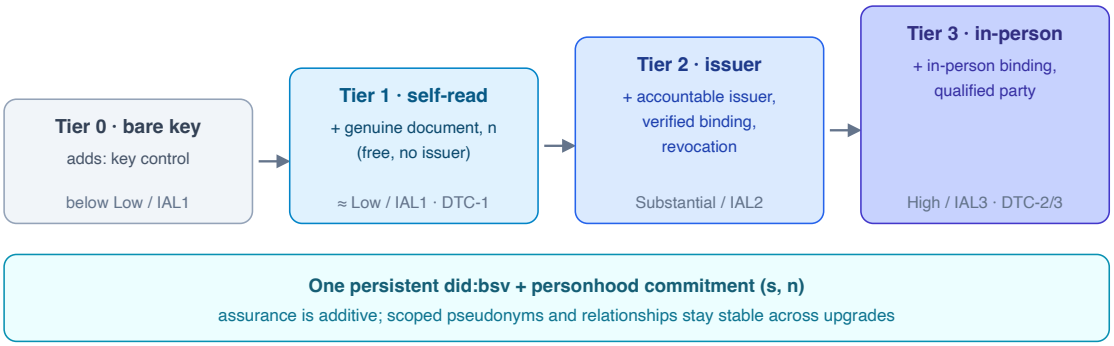


Figure 2. Additive tiers over one identity (Spec §12).

Tier 0 is a bare identity key: proof of key control, no document, no commitment. **Tier 1** is the free self-read: the holder scans the passport's machine-readable zone to derive the chip access key, reads the chip, and the wallet performs ICAO 9303 passive authentication, checking the chip's signature and data-group

hashes against the issuing state's signing PKI. Where a uniqueness guarantee is relied upon, the wallet must also perform active/chip authentication, because passive authentication alone does not detect a cloned chip, and cloning would defeat the uniqueness anchor. (A share of circulating passports, notably US ones, support neither; a deployment publishes a capability matrix and registers such documents without a uniqueness guarantee rather than silently downgrading.) The genuine attributes derive the nullifier `n`; a fresh secret `s` is generated and held in the wallet. The trust anchor is the issuing state's document PKI; there is no third-party issuer, which is what makes the tier free. Enrolment is correspondingly **verifiable without a trusted attester**: the wallet submits the blinded commitment, the deterministic uniqueness tag, and the enrolment proof to a multi-party registry that admits one active registration per tag under a specified state machine (Spec Appendix F). The tag is chip-recomputable and therefore personal data, so it lives off-chain with the registry operators, access-controlled and erasable; only salted registry roots touch the chain (Spec §10.7, §15.3, per the EDPB's blockchain guidelines). A stolen or pre-read passport enrolled by the wrong party is remedied by accountable eviction: a Tier-2/3 proofing event over the same document displaces the Tier-1 registration (Spec §12). **Tier 2** adds an accountable issuer or qualified trust service provider performing real identity proofing with liveness binding, remotely, under ETSI TS 119 461 v2.1.1 (passive and chip authentication, a DG2 face match, certified presentation- and injection-attack detection, and an audit trail), plus issuer-side revocation; and since CIR (EU) 2026/798 (April 2026) a reinforced remote flow reaches LoA High *without physical presence*. **Tier 3** is in-person (or supervised-equivalent) proofing, the other route to High and toward government-grade assurance.

What Tier 1 does and does not establish:

Tier-1 property	Holds?
Genuine passport document	Yes
Genuine chip, resisting copied data / emulation (with active / chip authentication; assumes chip-key non-extractability and no relay)	Yes
Unique per document	Yes
Verified that the presenter is the rightful holder	No
Accountable issuer / regulatory KYC	No

Tier 1 establishes *what the document is*, never *who is holding it*.

Assurance crosswalk. The tier is a *proofing* level and maps across frameworks: Tier 0 ≈ below eIDAS Low / NIST IAL1; Tier 1 ≈ Low (informal) / ≈ IAL1, and is analogous to an ICAO Digital Travel Credential Type 1 derivation (not itself a DTC unless the ICAO DTC-1 structure is implemented, Spec §12); Tier 2 ⟶ Substantial / IAL2 / DTC Type 2; Tier 3 ⟶ High / IAL3 / DTC Type 2-3. NIST SP 800-63-4 deliberately separates identity proofing (IAL) from authenticator strength (AAL) and federation (FAL); only IAL maps to the tier, which is why custody and presentation mode are independent axes. (Spec §12.)

Passport lifecycle, and what `n` actually anchors. Because `n` derives from chip data and electronic passports carry no reliable cross-document person identifier, `n` is *per-document, not per-person*. Renewing or replacing a passport yields a new document number and therefore a new `n`; a lawful second document (dual citizenship, or a pre-expiry replacement) yields a second valid `n`. So Tier-1 global uniqueness is, precisely, one-account-per-passport-document, which is the exact sense in which it resists casual but not determined Sybil behaviour. This does not disturb a holder's relationships: per-RP pseudonyms derive from the wallet-held `s`, so renewing a passport leaves every existing pseudonym intact and only the global-uniqueness anchor `n` resets. Collapsing multiple documents to one person is exactly the accountable binding the higher tiers provide.

8. Credentials and presentation

The canonical credential is the W3C Verifiable Credential. A credential commits to both `s` and `n`, and is cryptographically bound to a holder key derived from the root identity; the sense in which it is "bound

to `did:bsv`" is key/control binding, not embedding the DID string, and the resolvable root DID is never exposed at presentation. Each attribute is individually addressable so it can be selectively disclosed or proven by predicate without revealing its neighbours.

Figure 3 · Credential lifecycle

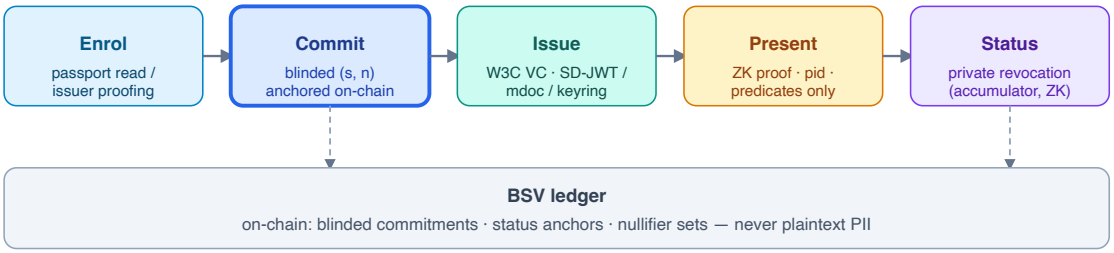


Figure 3. Credential lifecycle (Spec §11). Only blinded commitments and status anchors touch the chain.

A Tier-1 credential is **self-issued**: the wallet packages the genuine passport data groups with their passive-authentication evidence and commits `s`; its verifiability derives from the document PKI chain, not a third-party signature. A Tier-2/3 credential is signed by an accountable issuer, who may attest over the holder's *existing* commitment so an upgrade adds assurance without forking the identity.

A credential is expressible in any of three interoperable selective-disclosure encodings: **SD-JWT VC** (for EU interop; linkable, so not the sole encoding where unlinkability is required), **ISO/IEC 18013-5 mdoc** (for proximity/mobile-document and remote use), and **BRC-52/53 keyrings** (the BSV-native profile). Where §10 unlinkability is needed, the credential is additionally issuable in an anonymous-credential form (BBS+) or as a commitment a zero-knowledge circuit can consume.

Presentation runs over two protocols from one identity: **BRC-103** for BSV-native peer-to-peer mutual authentication (which also authenticates the relying party to the holder, defeating phishing), and **OpenID4VP with SIOP** for the W3C/eIDAS world. Disclosure granularity is set by the request: a bare pseudonymous login, a predicate-only proof (over-18 with no identity revealed), or full attribute disclosure under explicit per-disclosure consent. Sessions and single-sign-on are supported without becoming a correlation honeypot: the identifier exposed to each relying party is always the pairwise pseudonym, and a hosted bridge, if used, must not retain cross-RP correlation data. (Spec §§11, 14.)

9. The zero-knowledge toolbox

What makes this feasible on BSV is a separation of layers: the chain layer (DID operations, key derivation, signing) is fixed to secp256k1, but the **proof layer is not bound to that curve**, so a presentation proof may use whatever group its proof system needs. Pairing-based and SNARK-friendly constructions run in the credential layer while identity and control stay anchored on secp256k1. The standard fixes the *capabilities* required and the proof *statement*, not the proving system, which is pluggable.

The capabilities form four layers of increasing power: **(A)** selective disclosure (reveal chosen fields); **(B)** attribute predicates (prove age ≥ 18 without the date of birth, for example with Bulletproof range proofs, native to secp256k1, no trusted setup); **(C)** multi-show unlinkable presentation (each presentation's *credential proof* is uncorrelated even to the same verifier, for example with BBS+; the deliberately-stable scoped pseudonym `pid` remains the one intentional same-verifier link, by design, §6); and **(D)** a single succinct proof of the full statement: a credential is validly attested, predicates hold, and `pid = PRF(s, scope)` for a committed `s`, including, for Tier-1 self-read, verifying the ICAO passive-authentication signature chain in-circuit. The central technical task is the **binding problem**: proving that a hidden attribute is the one an accountable source attested, without showing a reusable signature that would itself be a correlation handle. Three strategies address it: an issuer-side commitment, signature-verification-in-circuit, or a zero-knowledge-native credential signature (BBS+/PS). (Spec §13.)

Feasibility, stated concretely. Layers A to C are production-ready *as primitives* and cheap on mobile (milliseconds to low seconds, small proofs), but primitive and library maturity is not the same as end-to-end binding maturity (the §9 binding problem), full-profile maturity, or EUDI-integration maturity, which are separate axes (the EU's own TS4 holds no evaluated ZKP approach mature enough for direct EUDI integration, §10). Layer D is the expensive case: the dominant cost is verifying the issuer's signature chain (RSA-2048 or ECDSA) inside the circuit, which runs to millions of constraints. It is nonetheless shippable on commodity phones today, and several production systems (ZKPassport, Self, OpenPassport, Rarimo) generate ICAO passport proofs on-device, but proving takes seconds to tens of seconds. The practical pattern is **amortization**: run the heavy passive-authentication proof *once* at enrolment, binding the passport to a published commitment and a registration entry; subsequent presentations then prove cheap membership against that registration plus the requested predicates, which are Layer-A/B-class costs. A real engineering cost is **heterogeneity**: states sign with different algorithms and key sizes (RSA, ECDSA, DSA, EdDSA; some legacy hashes), so a conforming Tier-1 circuit suite must cover several signature profiles, and issuer coverage, not single-circuit speed, is the gating factor. On-device proving preserves privacy; remote proving is faster but reveals inputs and is unsuitable for the privacy-critical Tier-1 self-read.

10. eIDAS interoperability

The eIDAS profile is a three-stage maturity path, each stage independently useful with an explicit exit gate.

Figure 5 · eIDAS maturity path



Figure 5. The eIDAS maturity path (Spec Part IV).

Stage 1 (interop bridge) lets a BSV service accept EU wallet presentations and issue attributes consumable as non-qualified attestations, registering with a member-state registrar for an access certificate. **Stage 2 (qualified)** issues qualified attestations through a qualified trust service provider, mapped onto EU Trusted Lists. **Stage 3 (notified eID)** is the wallet acting as the technical vehicle of a member-state-sponsored scheme at the highest assurance, a long-horizon, politically-gated destination.

Three reconciliations make the stages work. *Format:* the canonical internal model is the W3C VC (data model 2.0); at the EU boundary the binding acts require ISO/IEC 18013-5 and W3C VCDM 1.1 (SD-JWT VC is ARF-profile, not law), and since signatures are format-specific this means multi-format issuance, each encoding signed in its own right, including a 2.0⟶1.1 issuance profile, never signature-preserving "export" (Spec §19.1). *Trust:* a verifier can resolve trust either through EU Trusted Lists or through the on-chain accredited-issuer registry. *Unlinkability:* the EU mandates unlinkability in principle (Recital 14 calls for zero-knowledge integration) and the ARF's own "full unlinkability" definition coincides with this design's goal. As of 2026 the ARF has acted on this: zero-knowledge proof is now a dedicated topic with high-level requirements in Annex 2 (next to a dedicated pseudonyms topic), referencing ETSI TR 119 476 and naming BBS+, the pairing-free ECDSA-compatible BBS#, zk-SNARKs, and ECDSA-based anonymous credentials. One requirement expects proofs to be generated over PIDs/attestations *already issued* as SD-

JWT VC or mdoc, and another forbids linkable ZKP interactions. But three things keep the gap real: deployment is deferred to after the December 2026 launch, so the live baseline is linkable and reaches verifier-unlinkability only by batch issuance; the ARF's leading ECDSA-compatible candidate (BBS#) needs per-presentation interaction with the issuer, whereas this design's zero-knowledge path is offline; and the recent relaxation of device binding to "recommended" eases anonymous credentials without changing the launch baseline. The useful consequence: because the ARF's own ZKP requirements describe proving over already-issued SD-JWT/mdoc credentials without linkability, this layer is positioned not merely as *ahead of* the EU baseline but as a candidate **conformant zero-knowledge presentation layer for ARF-issued credentials**. That is scoped honestly: the ARF requirement literally describes proving over credentials *already issued* as SD-JWT VC or mdoc, which is a substantially heavier circuit than this design's enrolment-commitment statement, so the claim attaches to the BBS# track as specified, with SD-JWT/mdoc-in-circuit proving a named roadmap item; and the EU's own TS4 ZKP specification currently holds that *no* evaluated approach is mature enough for direct EUDI integration, making this roadmap positioning, not a present conformance claim. A fourth reconciliation concerns pseudonyms: the EU's implementing regulation (CIR 2024/2979 Annex V) defines wallet pseudonyms via WebAuthn, which `pid` is not, so a conforming bridge runs dual-stack, WebAuthn pseudonyms for the legal obligation and `pid` for the zero-knowledge path (Spec §19.7). In short: the zero-knowledge path is unlinkable from day one and offline; the baseline-format path inherits the EU baseline's linkability until the ARF's ZKP track is deployed. (Spec §§16-19.)

11. Security and privacy

The adversaries of concern are colluding relying parties, an issuer colluding with relying parties, a network observer, a key/device thief, a holder presenting a stolen or copied credential, and a compromised trust anchor. Cross-RP correlation is defeated by scoped pseudonyms and the zero-knowledge presentation; issuer-RP collusion is mitigated because the issuer observes neither presentations nor status checks and a presentation can prove issuer-set membership without naming the issuer. Replay, and relay by a malicious app over its own session, is defeated by binding every proof to a fresh verifier challenge derived from a transcript that pins the scope, the verifier's identity, and the holder's presentation key; and a copied credential is unusable because presentation requires proof of holder-key control and knowledge of `s`. Proof bytes themselves are re-randomizable and are never used as identifiers.

Several limits are stated plainly rather than hidden. **Network-level correlation** (IP, timing, device fingerprint) is where most practical deanonymization happens, and the unlinkability guarantee is *cryptographic*: it does not extend to the network layer. Real deployments need transport-level measures (oblivious HTTP or a mixnet/Tor-style relay, plus timing padding and batched submission), and the design is explicit that cryptographic unlinkability must not be marketed as network anonymity. **On-chain confidentiality** depends on every anchored commitment being blinded with high-entropy salt; this matters most for `n`, which chip readers can recompute and which never appears on-chain at all. The enrolment registry's deterministic uniqueness tag is held off-chain by the operator set, access-controlled and erasable, so testing *whether a document has enrolled* (nothing more) requires both chip data and registry query access (Spec §10.7, §15.3). **Root-secret exposure is not contained by key rotation**, since `s` derives from it and cannot rotate without changing every pseudonym, so the spec defines an explicit compromise path: `s`-migration with per-relationship pid handover, gated on re-enrolment of the same document, or threshold proving so no device ever materializes the secret (Spec §8.10, §20.3). Device loss with intact secure-element custody remains an ordinary recovery event. **Tier-1 binding is self-asserted**, so a lost or stolen passport could be self-read by another party. And **secp256k1 signatures are not post-quantum**; migration is possible through DID key rotation as post-quantum schemes mature, and is a tracked long-term item. (Spec §20.)

Three further properties. Because presentation authenticates cryptographic key control rather than a live biometric, the deepfake and injection attacks that plague biometric authentication never reach the presentation path; biometrics appear only at Tier-2/3 enrolment. That biometric proofing is 1:1 verifi-

cation anchored on the document-derived nullifier, not 1:N face matching, so it stays in the EU AI Act's lower-risk lane (a deployment must not drift into 1:N identification or sensitive-trait categorisation). And unlinkability carries an honest cost: the protocol cannot trace an abuser across services, so accountable linkage exists only through per-RP banning, Tier-2/3 eviction, or the regulated CDD-retrieval path, and any broader lawful traceability must be added explicitly, never assumed. (Spec §15.2, §20.5, §20.8.)

On data protection, the architecture keeps personal data off-chain and writes only blinded, **confidentiality-protected (pseudonymous, not proven anonymous)** commitments to the ledger, which is designed to support the argument that the chain's immutability does not conflict with the right to erasure. Whether such commitments are "personal data" is a contested legal question, since for a party that retains the record, witness, or account relationship a commitment may remain personal data even if a random observer cannot interpret it, so it must be confirmed with data-protection counsel; this is design rationale, not legal advice.

12. How it compares

System	Verifiable KYC	Private (selective disclosure)	Unlinkable across services
Traditional KYC	Yes	No	No
EU Digital Identity Wallet (baseline SD-JWT / mdoc)	Yes	Partial	Partial, batch issuance only
Microsoft Entra Verified ID	Yes	Partial	No
SpruceID (mDL / state wallets)	Yes	Partial	No
Dock / Truvera	Yes	Yes	Partial (BBS+)
World ID	Personhood only	Partial	Yes (nullifiers)
Privado ID / Billions (ex-Polygon ID)	Yes	Yes	Yes
This proposal	Yes (Tiers 1-3)	Yes	Yes (zero-knowledge path)

World ID delivers unlinkable proof-of-unique-personhood but no attribute KYC, and depends on dedicated iris-scanning hardware with the attendant privacy and governance controversy. The **EU wallet** has decisive regulatory backing but ships linkable baseline formats, with zero-knowledge support written into the ARF yet deferred to after the December 2026 launch. The closest peer is **Privado ID / Billions** (the former Polygon ID team), which also does passport-based zero-knowledge identity, on an EVM ecosystem, without a defined eIDAS-notification path. The distinctive combination here is verifiable government-attribute KYC, proof of unique enrolment (per passport document at Tier 1, per person only at the accountable tiers), unlinkability, and a concrete eIDAS path, anchored on a high-throughput public UTXO ledger and entered through a free self-serve passport scan. The unlinkability advantage holds on the zero-knowledge path. (Spec §22.)

13. Roadmap and status

Delivery is phase-gated. **Phase 0** builds the substrate: `did:bsv` resolution, key management and recovery, BRC-103 and OpenID4VP presentation, the W3C VC model with multi-format SD-JWT VC issuance (never signature-preserving export), Tiers 0 and 1 including free self-read onboarding, and Layer-A selective disclosure, corresponding to the Stage-1 bridge. **Phase 1** adds the zero-knowledge layers B to D, the enrolment registry with membership proofs, and the SD-JWT/mdoc-in-circuit work item toward ARF ZKP conformance, which is the privacy differentiator. **Phase 2** adds qualified interoperability

(a qTSP partnership, Trusted List mapping, mdoc, full HAIP conformance). **Phase 3** is national scale (notified eID at the highest assurance). Beyond that, legal-person and organisational identity is future work, anchored on the Legal Entity Identifier (LEI) and its verifiable form (vLEI) and bridged through the delegation model.

Two risks bound the ambition. The heaviest zero-knowledge proofs are real engineering, mitigated by amortizing passive authentication into a one-time enrolment. And Stage 3 carries a prior strategic risk, whether EU regulators will anchor a notified scheme on a public, permissionless ledger at all, which is now evidenced rather than hypothetical: at least one early member-state wallet pilot was abandoned partly because a blockchain-and-ZKP stack did not meet baseline secure-hardware requirements, and commentary expects advanced cryptography and public-ledger anchoring to be admitted only at a later, cautiously certified stage. The design's answer is on-device proving, secure-element key custody, and only blinded commitments on-chain, but the burden of proof sits with this profile, and Stages 1 and 2 are deliberately structured not to depend on the answer.

The strongest near-term wedge is the **free, private, unique-per-document passport tier**: useful on day one for age-gating, Sybil-resistant accounts, and bot resistance, at one account per passport document, which is what the cryptography actually proves, with a clean upgrade path to regulated KYC, per-person guarantees at the accountable tiers, and, eventually, government identity.

For normative requirements, data schemas, the `did:bsv` profile, and conformance, see the companion standards proposal.